TECHNICAL REVIEW & QUALITY AUDIT REPORT

LightGBM · YARA-X · 로지스틱 회귀 기반 PE 정적 분석 대시보드

미니 프로젝트 제출 산출물 정밀 검증 및 고도화 피드백 보고서

검토 대상자	제출 파일 수	검토 일시	검토 기관 / 담당
구명회	총 18개 (PPTX 1, MD 1, PNG 2, MP4 1, TXT 12)	2026년 11월 06일	DMDG 기술심사위원회 (Sherlock & Craig)

EXCELLENT (A-)

88

TOTAL SCORE / 100

1. 정적 피처(528) & LightGBM 모델링	**90점**
2. 과학적 검증 엄격성 & 정직성	**96점**
3. XAI(pred_contrib) & 오류 방어 설계	**91점**
4. Streamlit 5탭 대시보드 & JSON 보고서	**87점**
5. 결합 성능 실증 & 배포 이식성	**76점**

1. 총평 및 핵심 심사 의견 (Executive Summary)

종합 평가 A-

🏆 **타협 없는 과학적 검증 태도와 실패/오류 구분 아키텍처(판정 불가 처리) 모범적**

EMBER2024(120,000건, 528피처) LightGBM, ReversingLabs MIT 공개 YARA-X 1.22.1(14개 규칙), L2 로지스틱 회귀 결합(z = -3.59571 + 6.05222·x1 + 0.07768·x2)을 체계적으로 구현했습니다. 특히 최종 홀드아웃 평가(100건)에서 단독 LightGBM(정확도 94%, 누락 4)보다 결합 모델(93%, 누락 5)이 더 낮았음을 숨기지 않고 정직하게 보고한 점과 오류를 정상으로 취급하지 않고 '판정 불가'로 처리한 설계가 압권입니다.

⚠️ **YARA 양성 표본 희소성(학습 1건·평가 0건)으로 결합 가중치 미작동 및 로컬 종속 실행**

결합 학습(301건)에 YARA 매칭 양성이 theZoo WannaCry 단 1건뿐이었고 검증/최종 평가(200건)에서는 매칭이 0건이어서, YARA 가중치(0.07768)가 실질적 보완 효과를 내지 못했습니다. 또한 I386 PE32(비-.NET, 32MiB 이하)만 지원하며, 실행 가이드('웹사이트 열기.txt')가 특정 로컬 PC 경로(127.0.0.1:8503)에 고정되어 있습니다.

제출 파일명	파일 형식	검증 상태	핵심 검증 결과 요약
미니프로젝트.pptx & 발표/01~11.txt	PPTX + 스크립트 11종	우수 (구조화)	11장 슬라이드별 핵심 메시지·주의사항·출처까지 완벽 명세(PPT 본문은 이미지)
v1 feature 기준.md / 이미지 2종	기술 명세 & 표	우수	초기 V1 27피처(LR Acc 0.8377) 이력, 14개 YARA 규칙표 및 점수계산 기준 명시
미니 프로젝트 웹사이트 열기.txt	로컬 실행 스크립트	이식성 보완	C:\Users\user\... 로컬 가상환경 및 127.0.0.1:8503 종속 실행 명령
미니 프로젝트 시연영상.mp4	시연 영상	정상 첨부	Streamlit 5탭 대시보드 및 JSON 보고서 다운로드 시연 확인

2. 모델 성능·결합층 수식 및 평가 결과 정밀 감사 (Detailed Technical Audit)

기술 감사

📌 [홀드아웃 평가 검증] 단독 LightGBM vs 로지스틱 회귀 결합 모델 비교 (고정 임계값 0.5)

정직한 평가 모범

DikeDataset(정상 malice=0, 악성 ≥0.8, SHA256·imphash 분리) 기반 검증 100건 및 최종 평가 100건(각 정상 50/악성 50) 실측 결과입니다.

평가 세트	모델 방식	악성 누락(FN)	정상 오탐(FP)	정확도(Acc)	재현율(Recall)
검증 (100건)	단일 LightGBM (528피처)	4건	4건	92%	92%
검증 (100건)	로지스틱 회귀 결합 모델	6건	3건	91%	88%
최종 (100건)	단일 LightGBM (528피처)	4건	2건	94%	92%
최종 (100건)	로지스틱 회귀 결합 모델	5건	2건	93%	90%

📌 [아키텍처 & XAI] 모델 수식, YARA-X 규칙 및 대시보드 구현 내역

XAI & 안전설계

- **결합 수식 검증:** z = -3.59571 + 6.05222·x1 + 0.07768·x2 (YARA=0일 때 0.5 분기점은 LightGBM 0.59411과 동치 → 기존 0.5 대비 악성 판정 문턱이 올라가 누락 1건 증가 원인 규명).
- **XAI 구분 설명:** LightGBM pred_contrib(기준값+기여도 합=원시점수)와 YARA 패턴 오프셋을 분리 표시해 '결합 점수 SHAP 오해'를 원천 방지.
- **웹 5탭 & 보안 처리:** 쉬운 결과 설명 / 모델 특징 / YARA 근거 / 결합 수식 / JSON 보고서. 업로드 파일은 메모리에서만 처리하고 실패 시 이전 상태 초기화.

💡 기술진 종합 소견

본 미니 프로젝트는 단기간 내 구현 범위와 실험 한계를 명확히 설정한 상태에서 핵심 파이프라인 동작을 검증했습니다. 3장에서 제시한 교정 사항 및 코드 개선안을 반영하면 차기 최종 프로젝트 또는 실무 포트폴리오로서 완성도가 한 단계 도약할 것입니다.

3. 발견된 결함 교정 및 즉시 개선 솔루션 (Audit Fixes & Solutions)

교정 솔루션

📌 산출물·모델·인프라별 교정 사항

Action Items

대상 영역 / 파일	발견된 문제점 및 보완점	수정 제안 (Action Item)
YARA-X 규칙 14개	평가 200건에서 매칭 0건 → 결합 계수 0.07768 사실상 무력화	특정 패밀리 규칙 외 패커·행위 API·의심 섹션 등 범용 YARA-X 규칙군 확충
로지스틱 결합 임계값	고정 0.5 기준이 LightGBM 단독 0.594로 상향되어 Recall 2%p 하락	Recall 보장을 위한 임계값 재조정 또는 규칙 매칭 시 조건부 가중 상향(OR 게이트)
지원 포맷 제약	I386 PE32 비-.NET 파일로 제한 (64비트 PE32+/.NET 미지원)	PE32+ 및 .NET 메타데이터 파서 확장으로 현업 실행파일 커버리지 확보
웹사이트 실행 방식	로컬 PC 절대경로(.venv-rebuild) 의존 실행 텍스트	Dockerfile + docker-compose.yml 패키징으로 원클릭 재현 환경 제공

🔧 [Fix 1] YARA 매칭 시 보수적 상향 & 임계값 재보정 (Recall 손실 방지)

```
# 결합 모델 임계값 0.5 적용 시 LightGBM 0.59411 이상만 악성 판정되는 역전 방지
prob_lgbm = booster.predict(feat_528)[0]
yara_hit = 1 if len(yara_matches) > 0 else 0
# YARA 확정 규칙 매칭 시 즉시 의심 상향, 미매칭 시 최적화된 Val 임계값(예: 0.45) 적용
final_flag = (yara_hit == 1) or (prob_fusion >= OPTIMAL_VAL_THRESHOLD)
```

🔧 [Fix 2] 로컬 경로 종속 제거를 위한 Docker Compose 표준 실행

```
docker build -t pe-static-xai:v1 ./malware_analysis_project
docker run --rm -p 8503:8503 --network none pe-static-xai:v1
```

4. 발표·고도화 핵심 전략 & 최종 점검 체크리스트 (Success Strategy)

합격 가이드

🎯 1. '과학적 정직성'을 최고의 강점으로 어필

발표 전략

결합 모델이 단독보다 1%p 낮았음을 솔직히 분석하고 '왜 0.594로 컷오프가 올라갔는지' 수학적으로 설명하는 태도가 심사위원에게 최고 점수를 받습니다.

⚡ 2. '오류 ≠ 정상' 판정 불가 아키텍처

안전 설계

파싱 실패·비지원 포맷을 정상으로 통과시키지 않고 '판정 불가'로 격리하는 보안 제1원칙(Fail-Closed)을 강조하세요.

🔍 3. 11장 발표 스크립트와 PPT의 일치화

자료 완성도

01~11.txt의 매우 정교한 '작성 주의사항'과 수치들을 PPTX 본문 텍스트로도 옮겨 단독 가독성을 높이세요.

📼 4. YARA 양성 매칭 테스트 케이스 확충

고도화 방향

평가셋에 Emotet/LockBit/StealC 등 14개 규칙 실제 매칭 샘플을 최소 20~30건 이상 확보해 결합층 효과를 재검증하세요.

📋 최종 점검 체크리스트 (Sherlock Final Checklist)

구분	점검 항목	점검 내용 및 기준	상태
데이터/규칙	YARA 양성 평가 표본 확충	14개 규칙이 실제 반응하는 악성 표본 확보 및 범용 YARA 규칙 보강	보완 권고
모델링	결합 임계값(0.5) 재조정	LightGBM 단독 대비 Recall 저하가 발생하지 않도록 Val 임계치 최적화	수정 필요
지원범위	PE32+(64비트) 및 .NET 지원	I386 전용 한계 해소 및 최종 프로젝트(비PE 문서) 통합	고도화 예정
이식성	Docker 컨테이너 패키징	로컬 절대경로 실행 대신 Dockerfile 기반 재현성 확보	보완 권고
XAI/윤리	pred_contrib·한계 명시 검증	기준값 합산 무결성 및 '실험용 모델' 주의사항 준수 완벽	확인 완료

DMDG (당목담글) 교육사업본부 & AI 연구소 기술인증위원회

본 기술 검토서는 미니 프로젝트 제출 산출물(발표자료·스크립트·시연영상·배포URL)의 기술 무결성, 검증 엄밀성 및 발표 전달력을 종합 평가하여 발행되었습니다.
구명회 님의 성공적인 최종 프로젝트 도약을 응원합니다.